

TrustBench: Can Language Models Audit Security Compliance?

Varun Gurnaney

May 2026

Abstract

We introduce TrustBench, a benchmark for evaluating large language models on security compliance auditing. TrustBench presents models with synthetic audit evidence -- policies, configurations, access logs, termination records, and exception registers -- containing planted compliance gaps, and measures detection accuracy against ground truth. The benchmark includes 20 tasks across 8 SOC 2 controls at five difficulty levels, from single-document gap detection (D1) to materiality judgment under ambiguity (D5). D4-D5 tasks, which comprise 75% of the benchmark, test red herring filtering, noise document handling, and professional judgment. We evaluate 6 models from Anthropic and OpenAI. Claude Sonnet 4.6 leads at 82% average score, followed by Claude Opus 4.7 (72%) and GPT-5.5 (71%). Three D5 tasks average below 28% across all models, indicating that compliance judgment remains beyond current LLM capabilities. Code, tasks, and results are publicly available at github.com/varungurnaney/trustbench.

1. Introduction

Security compliance auditing is a labor-intensive process. A typical SOC 2 Type II audit involves reviewing hundreds of documents -- access control policies, IAM configurations, change management logs, backup records -- to determine whether an organization's controls are operating effectively.

GRC teams are already using LLMs for evidence review, gap analysis, and questionnaire responses. Yet no benchmark exists to evaluate how well models perform these tasks. The closest prior work is AIReg-Bench (Sherborne et al., 2025): 120 EU AI Act samples -- a single regulation at proof-of-concept scale.

We introduce TrustBench to fill this gap. TrustBench evaluates whether models can: (1) detect compliance gaps in policy documents, (2) cross-reference policies against configurations and logs, (3) distinguish real gaps from documented exceptions, and (4) make materiality judgments on ambiguous findings.

2. Benchmark Design

2.1 Task Structure

Each task simulates an audit scenario. The model receives a control to assess, an evidence package (1-8 documents), and an instruction to produce an audit report. Evidence includes policies (.md), IAM configs (.json), MFA policies (.json), access logs (.csv), termination records (.csv), exception registers (.csv), and screenshots (.png).

2.2 Difficulty Levels

- D1 (2 tasks): Single-document gap detection. The gap is stated in the evidence.
- D2 (1 task): Careful reading. The gap is buried in a table or timeline.
- D3 (2 tasks): Cross-referencing. Comparing multiple documents reveals the gap.
- D4 (8 tasks): Red herring filtering. Some gaps have valid exceptions. Noise documents included.

- D5 (7 tasks): Materiality judgment. Ambiguous scenarios where auditors would disagree.

Figure 1: Average Score by Difficulty Level

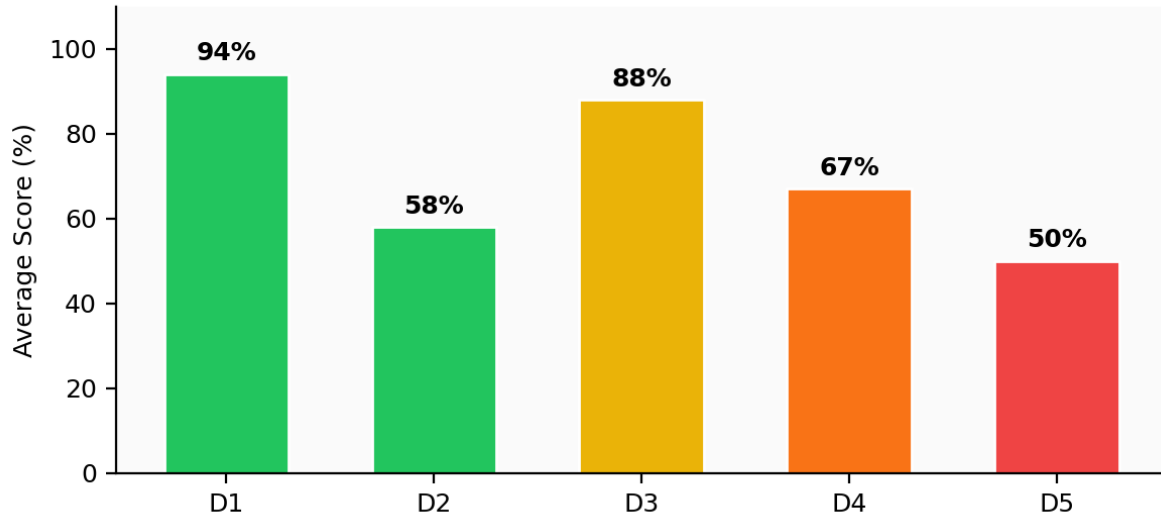


Figure 1: Average score by difficulty level across 6 models.

2.3 Scoring

D1-D2: detection scoring (recall). D3: detection with precision penalty. D4-D5: F1 -- the harmonic mean of recall (gaps found / total) and precision (true positives / total reported). F1 penalizes both missed gaps and over-reporting. Red herrings flagged without exclusion keywords count as false positives.

3. Experimental Setup

6 models evaluated on all 20 tasks (120 runs): Claude Sonnet 4.6, Opus 4.7, Haiku 4.5 (Anthropic); GPT-5.5, GPT-4.1, GPT-4o (OpenAI). Free-text output, default temperature, single run per model.

4. Results

4.1 Overall Performance

#	Model	Provider	Score	Recall	Prec.	Finds/Task
1	Sonnet 4.6	Anthropic	82%	92%	63%	7.3
2	Opus 4.7	Anthropic	72%	94%	47%	9.6
3	GPT-5.5	OpenAI	71%	82%	50%	8.7
4	GPT-4.1	OpenAI	61%	71%	48%	6.8
5	Haiku 4.5	Anthropic	61%	90%	39%	14.6
6	GPT-4o	OpenAI	44%	55%	38%	7.2

Table 1: Overall performance across 20 tasks.

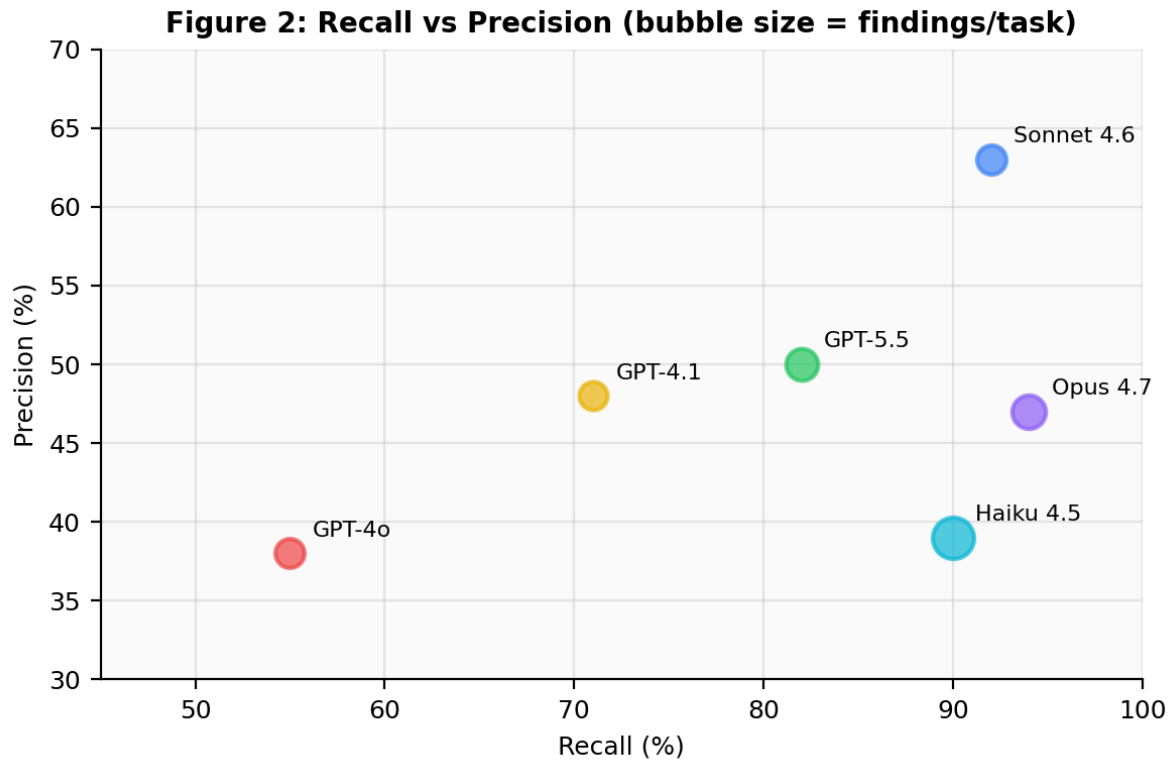


Figure 2: Recall vs Precision. Bubble size = avg findings/task.

4.2 Performance by Difficulty

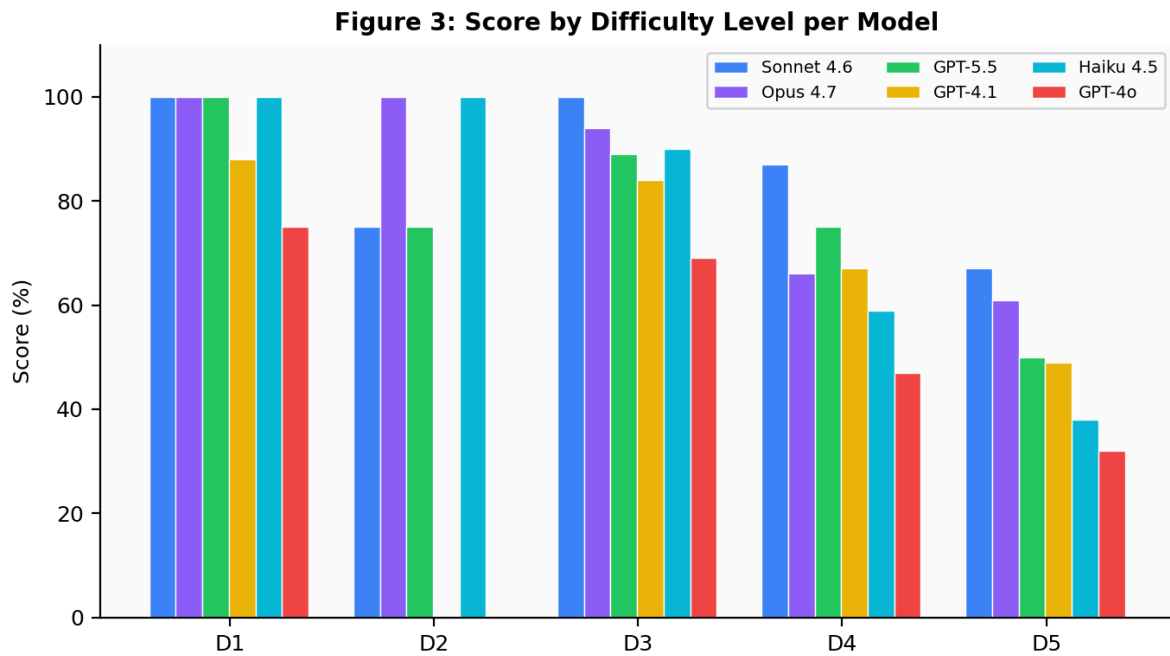


Figure 3: Score by difficulty per model. Performance diverges at D4-D5.

4.3 Performance by Control Domain

Figure 4: Score by Control Domain

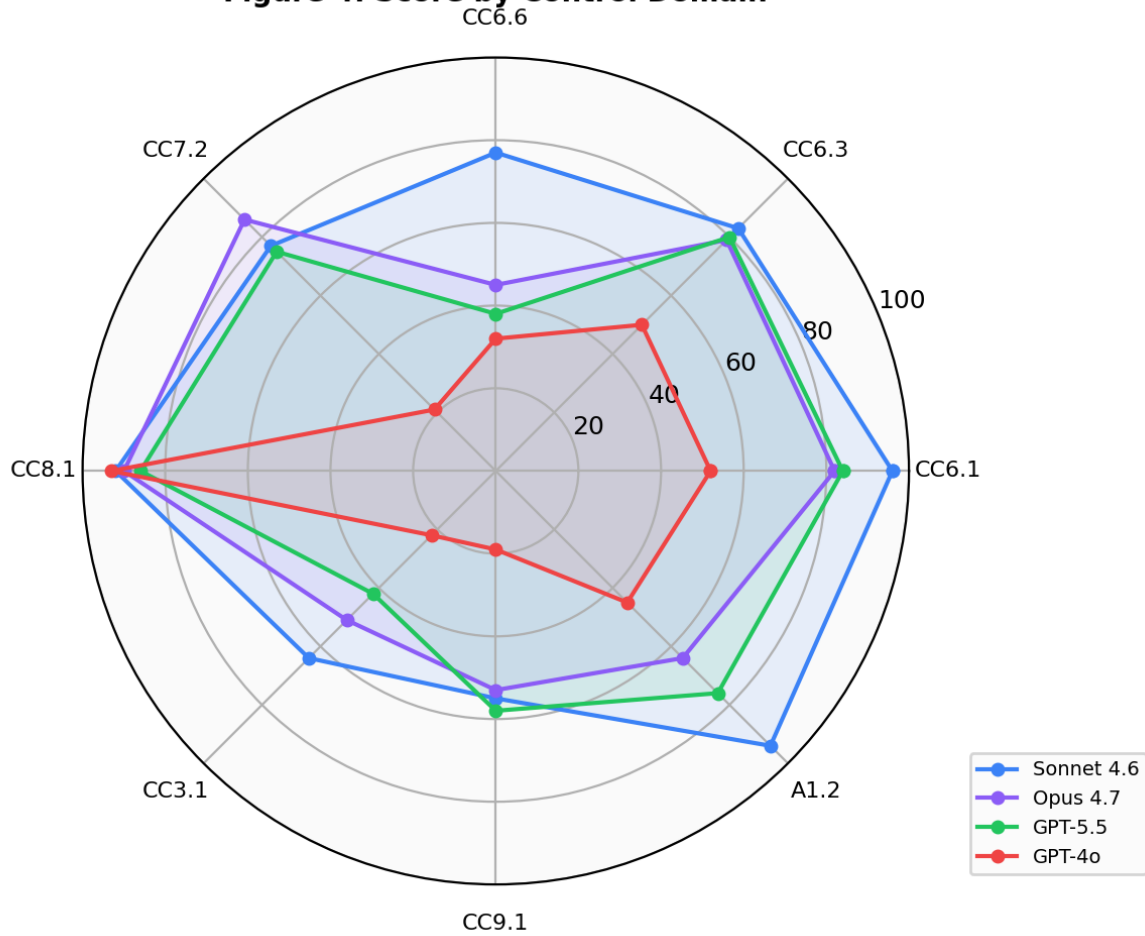


Figure 4: Score by control domain. Change Mgmt is easiest (88%), Vendor/Risk hardest.

4.4 D5 Judgment Tasks

- cc3.1-5-001 (Risk Assessment, 23%): Risk downgrades without justification, 11-month-old assessment.
- cc9.1-5-001 (Vendor Mgmt, 24%): Vendor met SLA but 3-week uncertainty on data exposure.
- cc6.6-5-001 (System Boundaries, 28%): Admin API bypasses gateway -- VPN-restricted, accepted risk.

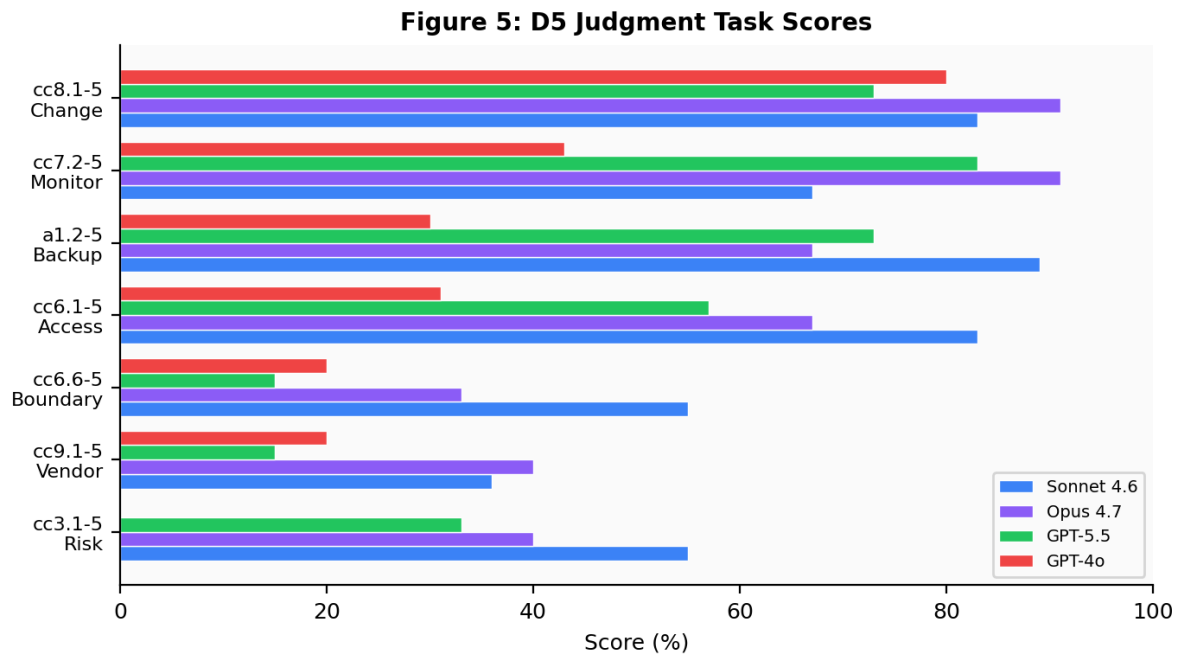


Figure 5: D5 task scores. No model above 40% on the three hardest tasks.

5. Analysis

5.1 Recall vs Precision

Most models achieve high recall. Scores diverge on precision. Haiku averages 14.6 findings/task but only 39% precision. Sonnet reports 7.3 findings/task with 63% precision. Compliance capability is about not over-reporting.

5.2 The Over-Reporting Penalty

F1 penalizes models that report findings beyond planted ground truth. Some extras may be legitimate. Opus reports 9.6 findings/task -- extras often include valid observations. This favors concise models. Sonnet's lead is partly driven by this, though it also has genuinely higher recall.

5.3 Model-Specific Blind Spots

No model dominates all controls. GPT-4o scores 93% on Change Mgmt but 19% on Vendor Mgmt. Domain-specific gaps suggest compliance capability is not a single dimension.

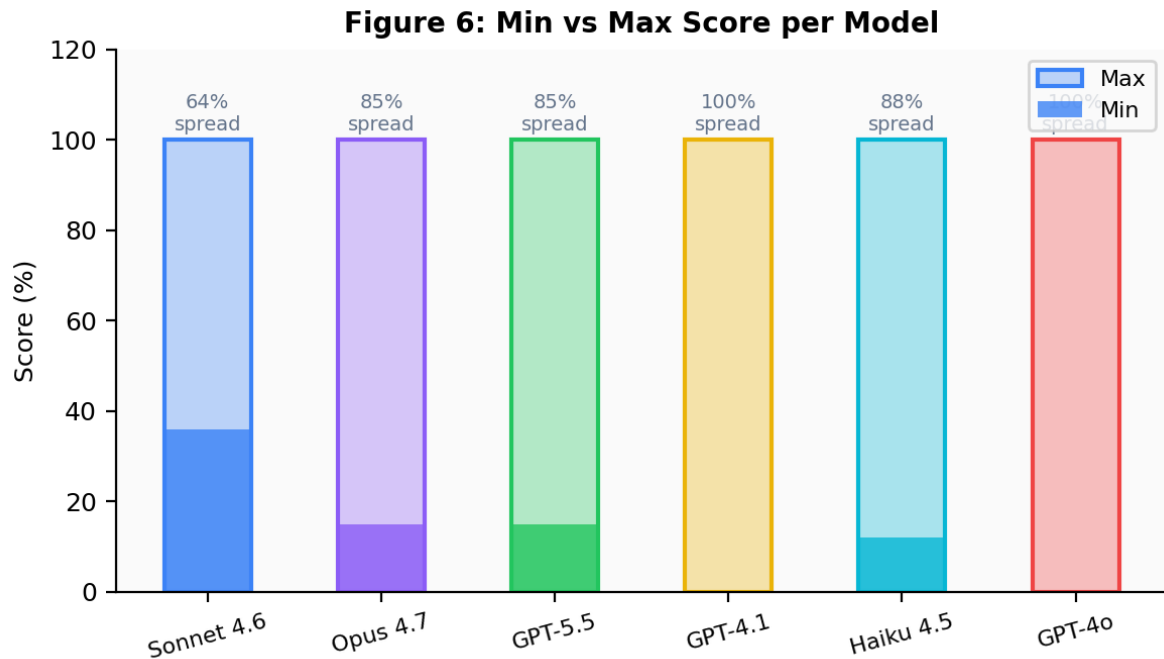


Figure 6: Min vs Max per model. Every model has at least one domain below 40%.

6. Limitations

- Task count: 20 tasks is directional, not statistically robust. Target: 64+.
- Keyword scoring: Cannot capture all valid phrasings.
- Over-reporting penalty: F1 penalizes legitimate extra findings. LLM-as-judge planned for v2.
- Single framework: SOC 2 only. Schema supports ISO 27001, HIPAA, PCI-DSS.
- Synthetic evidence: Modeled on real artifacts but may lack production complexity.

7. Related Work

SWE-bench (Jimenez et al., 2024): real GitHub issues, test-suite evaluation. CyBench (Zhang et al., 2024): 40 CTF challenges. CyberGym (Wang et al., 2025): 1,507 real CVEs. AIReg-Bench (Sherborne et al., 2025): 120 EU AI Act samples. LegalBench, CUAD, GAIA test adjacent skills. None test multi-document compliance auditing with exception handling and materiality judgment.

8. Conclusion

TrustBench demonstrates that LLMs can detect compliance gaps requiring cross-referencing -- practical value for GRC teams. However: (1) no model scores above 28% on materiality judgment, (2) models over-report creating false positives, (3) performance varies by control domain. Code and results: github.com/varungurnaney/trustbench.